

Phishing – Excel 4.0 Macros

Ticket :	SOC146 - Phishing Mail Detected - Excel 4.0 Macros
Mitre ATT&CK :	T1566
SMTP Address :	24.213.228.54
Device Action :	Allowed
E-mail Subject :	RE: Meeting Notes
Source Address :	trenton@tritoncomputers.com
Destination Address :	lars@letsdefend.io

A primeira coisa que pode ser observada aqui, é que o “device action” está como allowed, o que indica que o usuário recebeu o email

Date	Sender	Recipients	Subject	Final Action
2021-06-13 08:11:18	trenton@tritoncomputers.com	lars@letsdefend.io	RE: Meeting Notes	Unknown

From:	trenton@tritoncomputers.com
To:	lars@letsdefend.io
Subject:	RE: Meeting Notes
Sender IP:	24.213.228.54
Date:	2021-06-13 08:11:18
Action:	Unknown

Hello! Please inspect your docs as one document that you can find through the attachment.

Attachments

11f4453fb08d3307d87b01e9abff
Password: Infected

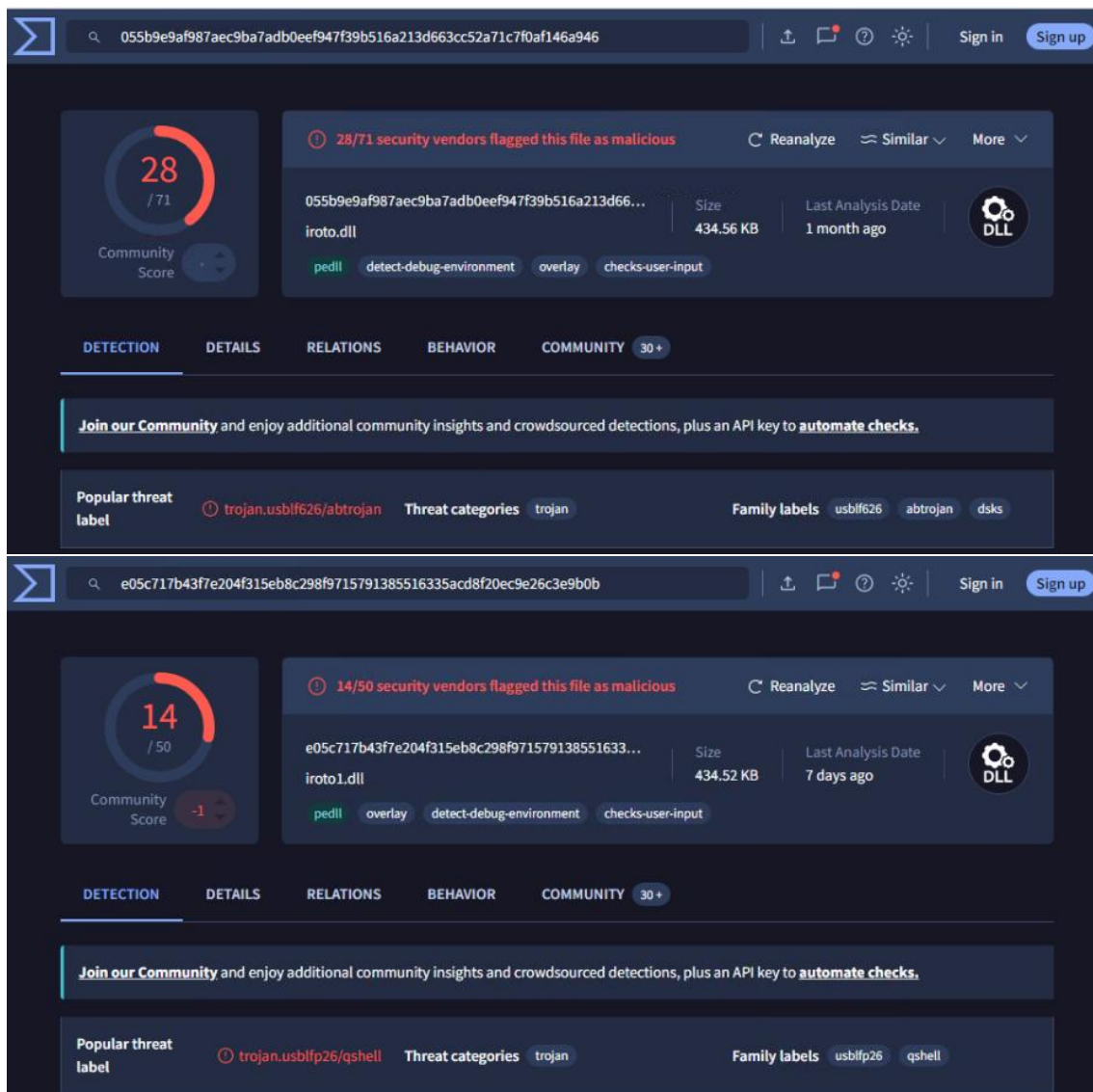
De acordo com os logs, apenas uma pessoa recebeu esse email.

Um email de outro domínio mandou um anexo para um email do domínio interno com um anexo, baixando o anexo em uma sandbox é possível checar seu comportamento, se é malware realmente ou não.

Organize	New folder	Name	Date modified	Type	Size
Quick access		iroto.dll	5/27/2021 9:06 PM	Application extens...	435 KB
Desktop		iroto1.dll	5/27/2021 9:06 PM	Application extens...	435 KB
Documents		research-1646684671.xls	6/13/2021 9:24 AM	XLS File	649 KB
Downloads					
Pictures					
This PC					
Network					

Extraindo o zip é possível observar 3 arquivos, 2 dlls e 1 xls

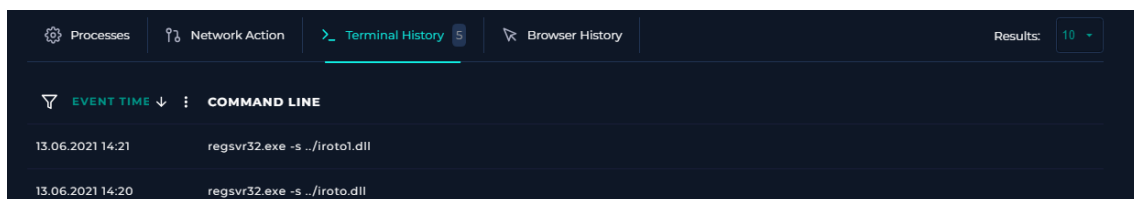
VirusTotal - File - 1df68d55968bb9d2db4d0d18155188a03a442850ff543c8595166ac6987df820			
virustotal.com/gui/file/1df68d55968bb9d2db4d0d18155188a03a442850ff543c8595166ac6987df820			
1df68d55968bb9d2db4d0d18155188a03a442850ff543c8595166ac6987df820			
40 / 62 Community Score	40/62 security vendors flagged this file as malicious		
1df68d55968bb9d2db4d0d18155188a03a442850ff543c8595166ac6987df820		Size	Last Analysis Date
research-1646684671.xls		648.50 KB	2 days ago
xls calls-wmi		XLS	
DETECTION	DETAILS	RELATIONS	BEHAVIOR
Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.			
Popular threat label		Threat categories	Family labels
trojan.x97m/dloadr		trojan downloader	x97m dloadr tioibesj



Analisando eles estaticamente vemos que todos são indicados como maliciosos, o que deve ser analisado agora é:

- Se a pessoa que recebeu o email, baixou e executou isso
- Se outras pessoas receberam o email
- Se outras máquinas foram comprometidas

Já foi observado que ele recebeu o email devido ao device action “Allowed”, agora se ele baixou e executou pode ser visto no EDR



^	No Event Time	No Process ID	regsvr32.exe	—	regsvr32.exe -s iroto.dll
MD5: b0c2fa35d14a9fad919e99d9d75e1b9e 					
Path: C:\Windows\System32\regsvr32.exe					
Size: 96.0 KB					
Parent: C:\Windows\System32\excel.exe					
▼	No Event Time	No Process ID	Cortana.exe	—	No Command
▼	No Event Time	No Process ID	OUTLOOK.exe	—	No Command
▼	No Event Time	No Process ID	svchost.exe	—	No Command
▼	No Event Time	No Process ID	wininit.exe	—	No Command
▼	No Event Time	No Process ID	TiWorker.exe	—	No Command
▼	No Event Time	No Process ID	explorer.exe	—	No Command
▼	No Event Time	No Process ID	regsvr32.exe	—	regsvr32.exe -s iroto.dll
13.06.2021 14:21 https://nws.visionconsulting.ro/NIGIKCXA/dot.html					
13.06.2021 14:20 https://royalpalm.sparkblue.lk/vCNhYrq3Yg8/dot.html					

De acordo com os registros de rede, processos e comandos, ele foi sim executado. No mesmo horário da execução 2 URLs foram acessadas

Também pode-se observar processos como OUTLOOK.exe, Cortana.exe, TiWorker.exe logo depois da dll ser executada, isso pode indicar que o malware está tentando utilizar processos legítimos do Windows para se camuflar e fazer requisições

É bom ver o comportamento do malware, como contatos com mais urls maliciosas e coisas que talvez não foram pegadas pelo sistema e poder checar com mais integridade se mais alguém acessou essas urls.

Checando se mais alguém recebeu o email:

Filters

All Time

All Emails

FILTERS (1)

Sender

contains

trenton@trilowcomputers.com

+ Add filter

Clear all

Recipients

Subject

Final Action

lars@letsdefend.io

RE: Meeting Notes

Unknown

Filters

All Time

All Emails

FILTERS (1)

Attachment Name

contains

Tf64531b-088d3307a87b01e8aeb

+ Add filter

Clear all

Recipients

Subject

Final Action

lars@letsdefend.io

RE: Meeting Notes

Unknown

Checamos de 2 formas, pelo email de quem enviou e pelo nome do conteúdo malicioso anexado, aparentemente apenas lars recebeu o email

Realizando uma análise dinâmica, aproveitando que é um malware conhecido, para poupar tempo, é bom utilizar uma análise pública já disponível no ANY.RUN, evitando a necessidade de executar novamente a amostra

Processes 3	Browser Data 0	new	Actions 0	beta
Filter by PID or name				
3732	EXCEL.EXE	C:\Users\admin\AppData\Local\Temp\research-1646684671.xls		
440	regsvr32.exe	-s ..\iroto.dll		
4308	regsvr32.exe	-s ..\iroto1.dll		

Danger 2
T1204.002 Malicious File (1)
Unusual execution from MS Office
T1218.010 Regsvr32 (1)
Registers / Runs the DLL via REGSVR32.EXE

Já vimos que é suspeito e o que ele executa

HTTP Requests

2

Connections

43

DNS Requests

25

Network Threats

Hide whitelisted

3732

PCAP

Timeshift

Headers

Rep

PID

Process name

CN

URL

Content

9680 ms

H1

GET | 200: OK

3732

EXCELEXE

🇺🇸

http://ocsp.digicert.com/MFEwTzBN...

471 b ↓

20913 ms

H1

GET | 200: OK

3732

EXCELEXE

🇺🇸

http://ocsp.digicert.com/MFEwTzBN...

471 b ↓

HTTP Requests

9

Connections

10

DNS Requests

25

Network Threats

Hide whitelisted

3732

PCAP

Timeshift

Protocol

Rep

PID

Process name

CN

IP

Port

Domain

ASN

Traffic

9607 ms

TCP

✓

3732

EXCELEXE

🇮🇹

52.109.76.240

443

officeclientL...

MICROSOFT-CO...

↑ 992 b ↓

9653 ms

TCP

✓

3732

EXCELEXE

🇮🇹

52.109.68.129

443

roaming.o...

MICROSOFT-CO...

↑ 1 Kb ↓

9677 ms

TCP

✓

3732

EXCELEXE

🇺🇸

52.113.194.132

443

ecs.office.c...

MICROSOFT-CO...

↑ 1 Kb ↓

9680 ms

TCP

✓

3732

EXCELEXE

🇺🇸

192.229.221.95

80

ocsp.digice...

EDGECAST

↑ 480 b ↓

9685 ms

TCP

✓

3732

EXCELEXE

🇧🇷

23.32.185.164

443

fs.microsof...

AKAMAI-AS

↑ 579 b ↓

10706 ms

TCP

⚠

3732

EXCELEXE

🇮🇹

188.209.214.83

443

nws.vision...

ROMARG SRL

↑ 578 b ↓

11705 ms

TCP

✓

3732

EXCELEXE

🇮🇹

52.111.236.21

443

nexusrules...

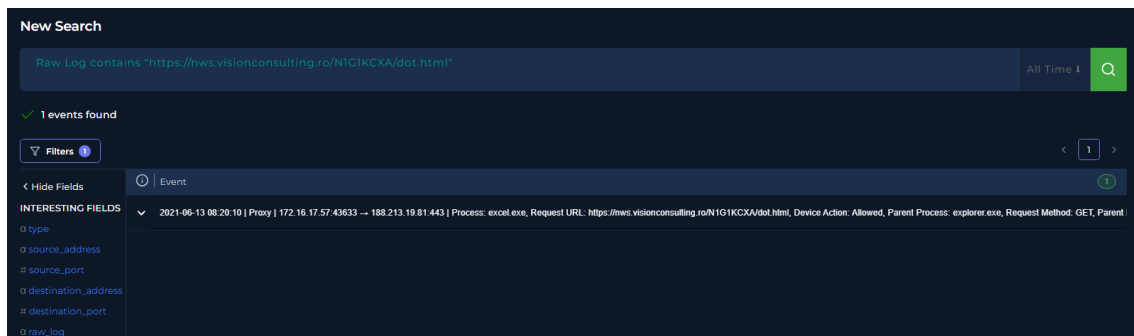
MICROSOFT-CO...

↑ 841 b ↓

Tentativas de conexão através da porta 443, talvez para tentar simular um tráfego legítimo para o que parece ser um C2

No caso é bom checar todas essas URLs e IPS maliciosos, no caso do laboratório vamos checar as 2 que o EDR detectou no horário da execução

New Search
Raw Log contains "https://royalpalm.sparkblue.ik/vCNhYrq3Yg8/dot.html"
1 events found
Filters
Hide Fields
INTERESTING FIELDS
q type
q source_address
q source_port
q destination_address
q destination_port
q raw_log
Event
2021-06-13 08:20:38 Proxy 172.16.17.57:45235 → 192.232.219.67:443 Process: excel.exe, Request URL: https://royalpalm.sparkblue.ik/vCNhYrq3Yg8/dot.html, Device Action: Allowed, Parent Process: explorer.exe, Request Method: GET, Pare



Aparentemente apenas a máquina de Lars acessou essas URLs

T1566 – Phishing

T1204 - User Execution

T1218 - System Binary Proxy Execution

T1071 - Application Layer Protocol

Horário:

13-06-2021 08:11:18

IoCs:

Endereços IP:

188.213.19.81

192.232.219.67

URLs:

<https://royalpalm.sparkblue.lk/vCNhYrq3Yg8/dot.html>

<https://nws.visionconsulting.ro/N1G1KCXA/dot.html>

Email Sender:

trenton@tritowncomputers.com

Hashes dos arquivos maliciosos:

1df68d55968bb9d2db4d0d18155188a03a442850ff543c8595166ac6987df820

055b9e9af987aec9ba7adb0eef947f39b516a213d663cc52a71c7f0af146a946

e05c717b43f7e204f315eb8c298f9715791385516335acd8f20ec9e26c3e9b0b

Vetor de Ataque:

Phishing, um email malicioso foi enviado para lars@letsdefend.io com um anexo malicioso e o usuário clicou e baixou o anexo

Análise:

O zip anexado continha três arquivos, um .xls e duas .dll.

O payload explorou o processo regsvr32.exe do windows para registrar as dlls maliciosas

Foram identificadas conexões suspeitas utilizando a porta TCP/443, possivelmente relacionadas à comunicação com o C2

Através dos processos pode-se observar que, devido a sequência temporal, ele pode estar tentando usar processos legítimos do Windows para evitar detecção e executar pesquisas, como Outlook.exe e Cortana.exe

Recomendações:

- Bloquear os IPs e domínios maliciosos
- Isolar o Host comprometido da rede
- Investigar possíveis indícios de comprometimento das credenciais do usuário e, caso identificado, realizar a contenção da conta e a redefinição de senha.
- Treinar funcionários para detectar emails de phishing
- Adicionar email Filtering, uma medida de proteção para filtrar emails vindos de fontes maliciosas conhecidas e detectar anexos suspeitos